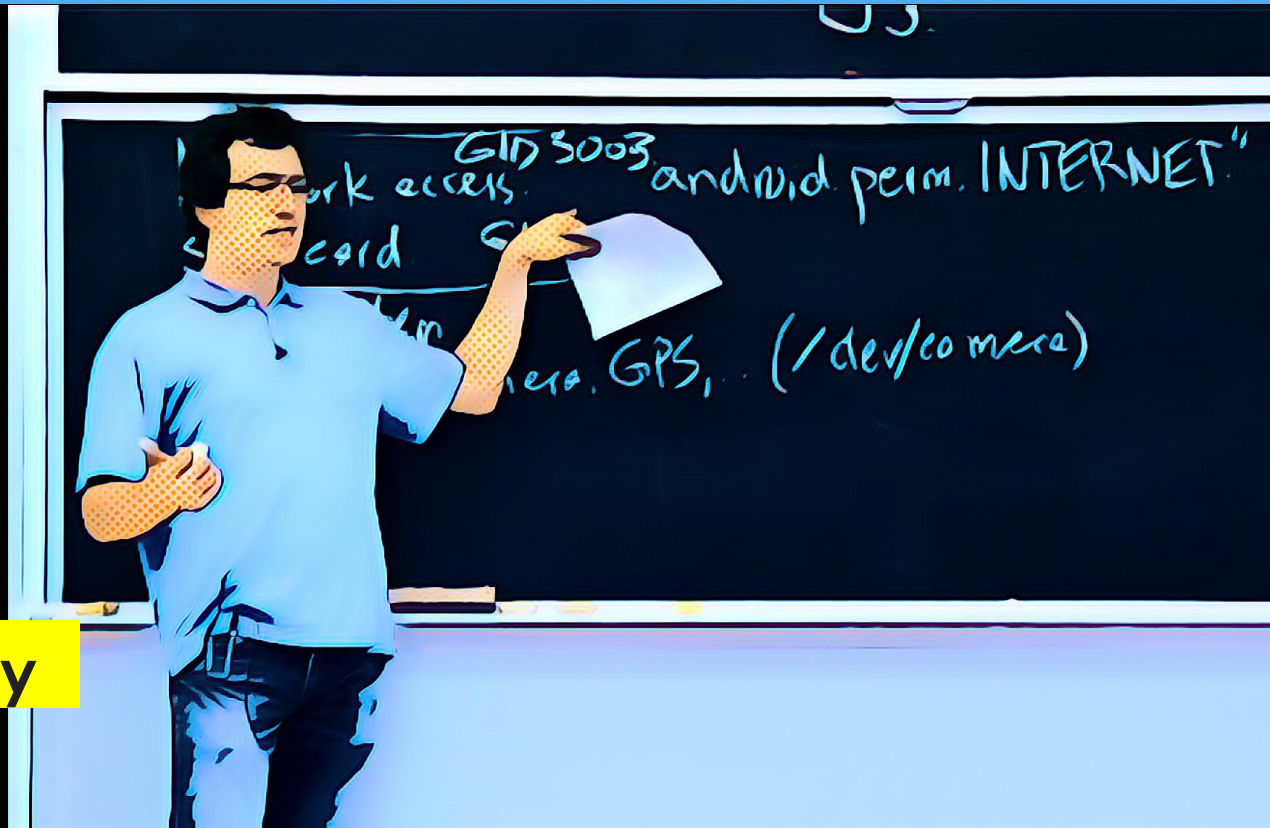
АНАЛИЗ УЯЗВИМОСТЕЙ ПРОЦЕССА АУТЕНТИФИКАЦИИ

Вадим Горбачев
@bmsdave

ОРЕЛШАУ

Последняя капля вдохновения

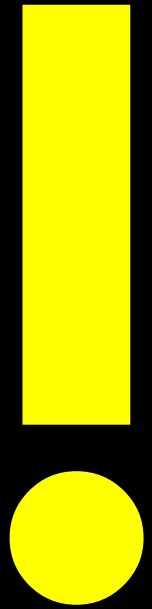
КУРС MIT “БЕЗОПАСНОСТЬ КОМПЬЮТЕРНЫХ СИСТЕМ“



В переводе
@uahosting.company
на хабре

ОТКАЗ ОТ ОТВЕТСТВЕННОСТИ

Материал не для использования в незаконных целях



ОТВЕТЫ ЮРИСТА

как избежать ответственности за поиск уязвимостей?

COOI STORY

Yahoo + Sarah Palin = ❤

COOI STORY

Yahoo + Sarah Palin = ❤

Где вы посещали школу?

Как звали вашего друга?

Когда у вас день рождения?

COOI STORY

Yahoo + Sarah Palin = ❤

Где вы посещали школу?
Как звали вашего друга?
Когда у вас день рождения?

Ответы нашлись в википедии ;)

COOl STORY 2

Twitter + Google + Apple + Amazon + Mat Honan = ❤

COOI STORY 2

Twitter + Google + Apple + Amazon + Mat Honan = ♥

WHOIS information for shouldibeworriedaboutswineflu.com:

```
[Querying whois.verisign-grs.com]
[Redirected to whois.joker.com]
[Querying whois.joker.com]
[whois.joker.com]
domain:       shouldibeworriedaboutswineflu.com
owner:        Mathew Honan
email:        mhonan@gmail.com
address:      530 Divisadero Street
address:      #284
city:         San Francisco
state:        CA
postal-code:  94117
country:      US
phone:        +1.4158940373
admin-c:      CCOM-1248066 mhonan@gmail.com
tech-c:       CCOM-1248066 mhonan@gmail.com
billing-c:    CCOM-1248066 mhonan@gmail.com
nserver:      ns2.sabren.com
nserver:      ns1.sabren.com
status:       lock
created:      2009-04-26 22:45:18 UTC
modified:     2011-03-03 19:36:13 UTC
expires:      2013-04-26 22:45:18 UTC
query-source: 204.202.20.53
contact-hdl:  CCOM-1248066
person:       Mathew Honan
email:        mhonan@gmail.com
address:      1559B Sloat Blvd
address:      #308
city:         San Francisco
state:        CA
postal-code:  94132
country:      US
phone:        +1.4158940373
```

1559B Sloat Blvd, San Francisco
mhonan@gmail.com

COOI STORY 2

форма восстановления пароля google:
резервный ящик
m••••n@me.com

COOI STORY 2

Ящики на me.com =
AppleID для AppStore.
Для восстановления пароля:

1) адрес почты @me.com;

2) адрес проживания;

3) последние 4 цифры кредитной карты, привязанной к AppleID.

COOI STORY 2

Ящики на me.com =
AppleID для AppStore.
Для восстановления пароля:

1) адрес почты @me.com;

2) адрес проживания;

3) последние 4 цифры кредитной карты, привязанной к AppleID.

COOI STORY 2

amazon

COOI STORY 2

Чтобы привязать карту нужно знать:

ФИО + Адрес + email

amazon

COOI STORY 2

Забыл пароль от аккаунта,
как вернуть?

ФИО + Адрес +

4 цифры свежедобавленной карты

amazon

COOl STORY 2

— Зайти в amazon
— Найти последние 4 цифры карты старого хозяина.

Вуаля!

amazon

COOI STORY 2

Главная
На связи
В курсе
Поиск
Is this Mat Honan?
@mat
Читать
Clan Vv3 and Phobia hacked this twitter
Ответить
Ретвитнуть
В избранное
9
РЕТВИТОВ
7
ИЗБРАННЫХ
4 августа 12 в 4:12 утра с помощью web · Разместить твит
Ответить @mat

COOl STORY 2

Выводы:

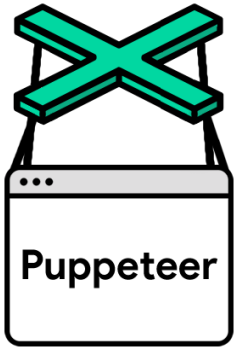
— Не всегда стоит идти на встречу пользователям

—Защиту нужно строить по всему периметру

—Аутентификация пользователя неимоверно важна

Давайте же окунемся в технические детали

Инструментарий:



ЗАДАЧА

по логину и паролю аутентифицировать пользователя.

Создадим таблицу:

```
CREATE  TABLE users (
  login TEXT NOT NULL UNIQUE,
  password TEXT NOT NULL
);
INSERT INTO users (login, password)
VALUES ('v1', '123456') ;
```

```
app.get('/api/v1/login', (req, res) => {
    conn.all(`
        SELECT rowid AS id, login, password
           FROM users
            WHERE login = '${req.query.login}'
        `,
        function (err, rows) {
            if (err) {
                res.send(err.message);
            } else {
                let loginFlag = false;
                if (rows && rows.length > 0) {
                    if (req.query.password === rows[0].password) {
                        loginFlag = true;
                    }
                }
                res.send(loginFlag ? 'logged in' : 'bad news');
            }
        })
});
```

```
app.get('/api/v1/login', (req, res) => {
    conn.all(`
```

```
SELECT rowid AS id, login, password
  FROM users
   WHERE login = '${req.query.login}'
```

```
            } else {
                let loginFlag = false;
                if (rows && rows.length > 0) {
                    if (req.query.password === rows[0].password) {
                        loginFlag = true;
                    }
                }
                res.send(loginFlag ? 'logged in' : 'bad news');
            }
        })
});
```

```
app.get('/api/v1/login', (req, res) => {
    conn.all(`
```

```
SELECT rowid AS id, login, password
   FROM users
    WHERE login = '${req.query.login}'
```

```
if (req.query.password === rows[0].password) {
    loginFlag = true;
}
```

```
                }
                res.send(loginFlag ? 'logged in' : 'bad news');
            }
        })
});
```

```
app.get('/api/v1/login', (req, res) => {
    conn.all(`
```

```
SELECT rowid AS id, login, password
   FROM users
    WHERE login = '${req.query.login}'
```

```
if (req.query.password === rows[0].password) {
    loginFlag = true;
}
```

```
res.send(loginFlag ? 'logged in' : 'bad news');
```

```
        })
});
```

```
app.get('/api/v1/login', (req, res) => {
    conn.all(`
        SELECT rowid AS id, login, password
```

```
SELECT rowid AS id, login, password
    FROM users
```

```
if (err) {
    res.send(err.message);
```

```
if
}
```

```
res.send(loginFlag ? 'logged in' : 'bad news');
```

```
});
```

```
app.get('/api/v1/login', (req, res) => {
    conn.all(`
        SELECT rowid AS id, login, password
           FROM users
            WHERE login = '${req.query.login}'
        `,
        function (err, rows) {
            if (err) {
                res.send(err.message);
            } else {
                let loginFlag = false;
                if (rows && rows.length > 0) {
                    if (req.query.password === rows[0].password) {
                        loginFlag = true;
                    }
                }
                res.send(loginFlag ? 'logged in' : 'bad news');
            }
        })
});
```

Login: v1
Password: 123456

http://127.0.0.1:3030/api/v1/login?login=v1&password=123456

GET http://127.0.0.1:3030/api/v1/login?login=v1&password=123456 Send

Params Authorization Headers Body Pre-request Script Tests Cookies Code

	KEY	VALUE	DESCRIPTION
☑	login	v1	
☑	password	123456	
	Key	Value	Description

Body Cookies Headers (6) Test Results Status: 200 OK Time: 5 ms 212 B

Pretty Raw Preview HTML

```
1 logged in
```

Login: bad
Password: bad

http://127.0.0.1:3030/api/v1/login?login=bad&password=bad

GET http://127.0.0.1:3030/api/v1/login?login=bad&password=bad Send

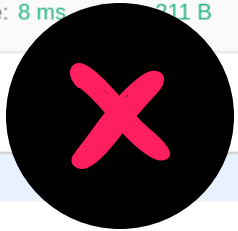
Params Authorization Headers Body Pre-request Script Tests Cookies Code

	KEY	VALUE	DESCRIPTION
☑	login	bad	
☑	password	bad	
	Key	Value	Description

Body Cookies Headers (6) Test Results Status: 200 OK Time: 8 ms 211 B

Pretty Raw Preview HTML

```
1 bad news
```



Login: bad'
Password: bad

http://127.0.0.1:3030/api/v1/login?login=bad'&password=bad

GET http://127.0.0.1:3030/api/v1/login?login=bad'&password=bad Send

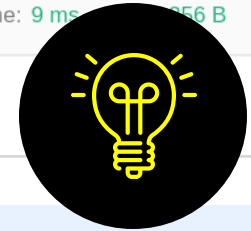
Params Authorization Headers Body Pre-request Script Tests Cookies Code

	KEY	VALUE	DESCRIPTION
☑	login	bad'	
☑	password	bad	
	Key	Value	Description

Body Cookies Headers (6) Test Results Status: 200 OK Time: 9 ms 256 B

Pretty Raw Preview HTML

```
1 SQLITE_ERROR: unrecognized token: "'bad'"
2 |       "
```



SQL INJECTION

```
WHERE login = '${req.query.login}'
```

```
SELECT rowid AS id, login, password
    FROM users
     WHERE login = 'bad''
```

SQL INJECTION

```
SELECT 1,2,3 UNION SELECT 3,2,1;
```

1	2	3
3	2	1

Login: bad' UNION SELECT 'test', 'test
Password: test

http://127.0.0.1:3030/api/v1/login?login=bad' UNION SELECT 'test', 'test&password=test

GET | http://127.0.0.1:3030/api/v1/login?login=bad' UNION SELECT 'test', 'test&password=test | Send

Params ● Authorization Headers Body Pre-request Script Tests Cookies Code

	KEY	VALUE	DESCRIPTION
☑	login	bad' UNION SELECT 'test', 'test	
☑	password	test	
	Key	Value	Description

Body Cookies Headers (6) Test Results Status: 200 OK Time: 6 ms 503 B

Pretty Raw Preview HTML

```
1 SQLITE_ERROR: SELECTs to the left and right of UNION do not have t n
    of result columns
```

Login: bad' UNION SELECT 'test', 'test','test
Password: test

http://127.0.0.1:3030/api/v1/login?login=bad' UNION SELECT 'test', 'test', 'test&password=test

GET http://127.0.0.1:3030/api/v1/login?login=bad' UNION SELECT 'test', 'test', 'test&password=test Send

Params Authorization Headers Body Pre-request Script Tests Cookies Code

	KEY	VALUE	DESCRIPTION
☑	login	bad' UNION SELECT 'test', 'test', 'test	
☑	password	test	
	Key	Value	Description

Body Cookies Headers (6) Test Results Status: 200 OK Time: 10 ms 312 B

Pretty Raw Preview HTML

```
1 logged in
```

SQL INJECTION

```
conn.all(`
    SELECT rowid AS id, login, password
       FROM users
        WHERE login = '${req.query.login}'
    `,
   function (err, rows) {
```

```
conn.all(`
        SELECT rowid AS id, login, password
        FROM users
        WHERE login = $login
    `, {
        $login: req.body.login
   },
   function (err, rows) {
```

Login: bad' UNION SELECT 'test', 'test','test
Password: test

http://127.0.0.1:3030/api/v1/login?login=bad' UNION SELECT 'test', 'test&password=test

GET | http://127.0.0.1:3030/api/v1/login?login=bad' UNION SELECT 'test', 'test&password=test | Send

Params | Authorization | Headers | Body | Pre-request Script | Tests | Cookies | Code

	KEY	VALUE	DESCRIPTION
☑	login	bad' UNION SELECT 'test', 'test	
☑	password	test	
	Key	Value	Description

Body | Cookies | Headers (6) | Test Results

Status: 200 OK | Time: 23 ms | Size: 211 B

Pretty | Raw | Preview | HTML

```
1 bad news
```

SQL INJECTION

Warning: Never, never,
NEVER use Python string concatenation (+) or string parameters interpolation (%) to pass variables to a SQL query string. Not even at gunpoint.

Psycopg

SQL INJECTION

Хмм.. Кажется мы что-то забыли? Не правда ли?

SQL INJECTION

Хмм.. Кажется мы что-то забыли? Не правда ли?

```
if (err) {
    res.send(err.message);
```

HTTP

HTTP

HTTP

GET

HTTP

	OSI Layer	TCP/IP	Datagrams are calle
Software	**Layer 7** Application	HTTP, SMTP, IMAP, SNMP, POP3, FTP	**Upper Layer Data**
	Layer 6 Presentation	ASCII Characters, MPEG, SSL, TSL, Compression (Encryption & Decryption)	
	Layer 5 Session	NetBIOS, SAP, Handshaking connection	
	Layer 4 Transport	TCP, UDP	**Segment**
	Layer 3 Network	IPv4, IPv6, ICMP, IPSec, MPLS, ARP	**Packet**
	Layer 2	Ethernet, 802.1x, PPP, ATM, Fiber	**Frame**

HTTPS

Создаем самоподписанный сертификат

```
openssl req -nodes -new -x509 -keyout
server.key -out server.cert
```

HTTPS

```
const fs = require('fs');
const https = require('https');
const privateKey = fs.readFileSync('./server.key', 'utf8');
const certificate = fs.readFileSync('./server.cert', 'utf8');
const credentials = {key: privateKey, cert: certificate};

const httpsServer = https.createServer(credentials, app);
httpsServer.listen(3030);
```

HTTPS

```
$ sudo tcpdump -i lo port 3030 -w
./dump.pcap  tcpdump: listening on lo, link-type
EN10MB (Ethernet), capture size 262144 bytes
67 packets captured
134 packets received by filter
0 packets dropped by kernel
$ wireshark ./dump.pcap
```

dump.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/> Expression...

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000…	127.0.0.1	127.0.0.1	TCP	74	55434 → 3030 [SYN] Seq=0 Win=43690 Len=0 MSS=65495 SACK_PERM=…
2	0.000…	127.0.0.1	127.0.0.1	TCP	74	3030 → 55434 [SYN, ACK] Seq=0 Ack=1 Win=43690 Len=0 MSS=65495…
3	0.000…	127.0.0.1	127.0.0.1	TCP	66	55434 → 3030 [ACK] Seq=1 Ack=1 Win=43776 Len=0 TSval=21937296…
4	0.002…	127.0.0.1	127.0.0.1	HT…	4…	GET /api/v1/login?login=v1&password=123456 HTTP/1.1
5	0.002…	127.0.0.1	127.0.0.1	TCP	66	3030 → 55434 [ACK] Seq=1 Ack=391 Win=44800 Len=0 TSval=219372…
6	0.023…	127.0.0.1	127.0.0.1	HT…	2…	HTTP/1.1 200 OK (text/html)
7	0.023…	127.0.0.1	127.0.0.1	TCP	66	55434 → 3030 [ACK] Seq=391 Ack=212 Win=44800 Len=0 TSval=2193…
8	1.032…	127.0.0.1	127.0.0.1	TCP	66	[TCP Keep-Alive] 55434 → 3030 [ACK] Seq=390 Ack=212 Win=44800…
9	1.032…	127.0.0.1	127.0.0.1	TCP	66	[TCP Keep-Alive ACK] 3030 → 55434 [ACK] Seq=212 Ack=391 Win=4…

```
▸ Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.0.0.1
▸ Transmission Control Protocol, Src Port: 55434, Dst Port: 3030, Seq: 1, Ack: 1, Len: 390
▾ Hypertext Transfer Protocol
  ▸ GET /api/v1/login?login=v1&password=123456 HTTP/1.1\r\n
    cache-control: no-cache\r\n
    Postman-Token: da376659-3366-4bc5-93ce-067da91136fb\r\n
    User-Agent: PostmanRuntime/7.6.0\r\n
    Accept: */*\r\n
```

```
0040  5d a5 47 45 54 20 2f 61  70 69 2f 76 31 2f 6c 6f   ]·GET /a pi/v1/lo
0050  67 69 6e 3f 6c 6f 67 69  6e 3d 76 31 26 70 61 73   gin?logi n=v1&pas
0060  73 77 6f 72 64 3d 31 32  33 34 35 36 20 48 54 54   sword=12 3456 HTT
0070  50 2f 31 2e 31 0d 0a 63  61 63 68 65 2d 63 6f 6e   P/1.1··c ache-con
0080  74 72 6f 6c 3a 20 6e 6f  2d 63 61 63 68 65 0d 0a   trol: no -cache··
0090  50 6f 73 74 6d 61 6e 2d  54 6f 6b 65 6e 3a 20 64   Postman- Token: d
00a0  61 33 37 36 36 35 39 2d  33 33 36 36 2d 34 62 63   a376659- 3366-4bc
00b0  35 2d 39 33 63 65 2d 30  36 37 64 61 39 31 31 33   5-93ce-0 67da9113
```

HTTP GET

Text item (text), 53 bytes Packets: 67 · Displayed: 67 (100.0%) Profile: Default

dump.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Expression...

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000…	127.0.0.1	127.0.0.1	TCP	74	56028 → 3030 [SYN] Seq=0 Win=43690 Len=0 MSS=65495 SACK_PER…
2	0.000…	127.0.0.1	127.0.0.1	TCP	74	3030 → 56028 [SYN, ACK] Seq=0 Ack=1 Win=43690 Len=0 MSS=654…
3	0.000…	127.0.0.1	127.0.0.1	TCP	66	56028 → 3030 [ACK] Seq=1 Ack=1 Win=43776 Len=0 TSval=220453…
4	0.001…	127.0.0.1	127.0.0.1	HT…	5…	POST /api/v1/login HTTP/1.1 (application/json)
5	0.001…	127.0.0.1	127.0.0.1	TCP	66	3030 → 56028 [ACK] Seq=1 Ack=461 Win=44800 Len=0 TSval=2204…
6	0.004…	127.0.0.1	127.0.0.1	HT…	2…	HTTP/1.1 200 OK (text/html)
7	0.004…	127.0.0.1	127.0.0.1	TCP	66	56028 → 3030 [ACK] Seq=461 Ack=212 Win=44800 Len=0 TSval=22…

```
› Ethernet II, Src: 00:00:00_00:00:00 (00:00:00:00:00:00), Dst: 00:00:00_00:00:00 (00:00:00:00:00:00
› Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.0.0.1
› Transmission Control Protocol, Src Port: 56028, Dst Port: 3030, Seq: 1, Ack: 1, Len: 460
› Hypertext Transfer Protocol
- JavaScript Object Notation: application/json
  - Object
    › Member Key: login
    › Member Key: password
```

```
01a0  6f 64 69 6e 67 3a 20 67  7a 69 70 2c 20 64 65 66   oding: g zip, def
01b0  6c 61 74 65 0d 0a 63 6f  6e 74 65 6e 74 2d 6c 65   late··co ntent-le
01c0  6e 67 74 68 3a 20 34 32  0d 0a 43 6f 6e 6e 65 63   ngth: 42 ··Connec
01d0  74 69 6f 6e 3a 20 6b 65  65 70 2d 61 6c 69 76 65   tion: ke ep-alive
01e0  0d 0a 0d 0a 7b 0a 09 22  6c 6f 67 69 6e 22 20 3a   ····{··" login" :
01f0  20 22 76 31 22 2c 0a 09  22 70 61 73 73 77 6f 72    "v1",·· "passwor
0200  64 22 3a 20 22 31 32 33  34 35 36 22 0a 7d         d": "123 456"·}
```

HTTP POST

JavaScript Object Notation (json), 42 bytes Packets: 7 · Displayed: 7 (100.0%) Profile: Default

dump.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/> Expression... +

No.	Time	Source	Destination	Protocol	Length	Info
37	46.81…	127.0.0.1	127.0.0.1	TCP	74	55474 → 3030 [SYN] Seq=0 Win=43690 Len=0 MSS=65495 SACK_P…
38	46.81…	127.0.0.1	127.0.0.1	TCP	74	3030 → 55474 [SYN, ACK] Seq=0 Ack=1 Win=43690 Len=0 MSS=6…
39	46.81…	127.0.0.1	127.0.0.1	TCP	66	55474 → 3030 [ACK] Seq=1 Ack=1 Win=43776 Len=0 TSval=2194…
40	46.81…	127.0.0.1	127.0.0.1	TLSv1.2	3…	Client Hello
41	46.81…	127.0.0.1	127.0.0.1	TCP	66	3030 → 55474 [ACK] Seq=1 Ack=263 Win=44800 Len=0 TSval=21…
42	46.82…	127.0.0.1	127.0.0.1	TLSv1.2	1…	Server Hello, Certificate, Server Key Exchange, Server He…
43	46.82…	127.0.0.1	127.0.0.1	TCP	66	55474 → 3030 [ACK] Seq=263 Ack=1297 Win=174720 Len=0 TSva…
44	46.82…	127.0.0.1	127.0.0.1	TLSv1.2	1…	Client Key Exchange, Change Cipher Spec, Encrypted Handsh…
45	46.83…	127.0.0.1	127.0.0.1	TLSv1.2	3…	New Session Ticket, Change Cipher Spec, Encrypted Handsha…
…	46.83…	127.0.0.1	127.0.0.1	TLSv1.2	5…	Application Data
47	46.86…	127.0.0.1	127.0.0.1	TLSv1.2	3…	Application Data, Application Data
48	46.90…	127.0.0.1	127.0.0.1	TCP	66	55474 → 3030 [ACK] Seq=828 Ack=1840 Win=179840 Len=0 TSva…

```
▸ Transmission Control Protocol, Src Port: 55474, Dst Port: 3030, Seq: 389, Ack: 1571, Len: 439
▾ Secure Sockets Layer
  ▾ TLSv1.2 Record Layer: Application Data Protocol: Application Data
    Content Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 434
    Encrypted Application Data: 30161e484c5daa989e55df5699464ea146605f346bec499f...
```

```
0040  14 97 17 03 03 01 b2 30  16 1e 48 4c 5d aa 98 9e   ·····0 ··HL]···
0050  55 df 56 99 46 4e a1 46  60 5f 34 6b ec 49 9f d4   U·V·FN·F `_4k·I··
0060  84 07 c8 f2 6b c9 e0 aa  1c cd 86 df a1 8e 33 ca   ····k··· ·····3·
0070  da 35 ff fa 92 9b c7 4e  3a 14 3f 8f 6a 7a 96 43   ·5·····N :·?·jz·C
0080  5c c5 1a 52 e0 3c d3 e1  9b c0 da ae aa 71 a6 43   \··R·<·· ·····q·C
0090  bb 83 69 d1 68 db 7a ba  a6 d2 31 90 83 32 63 21   ··i·h·z· ··1··2c!
```

HTTPS GET

Payload is encrypted application data (ssl.app_data), 434 bytes Packets: 67 · Displayed: 67 (100.0%) Profile: Default

dump.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/> Expression...

No.	Time	Source	Destination	Protocol	Length	Info
54	58.65…	127.0.0.1	127.0.0.1	TCP	74	55490 → 3030 [SYN] Seq=0 Win=43690 Len=0 MSS=65495 SACK_P…
55	58.65…	127.0.0.1	127.0.0.1	TCP	74	3030 → 55490 [SYN, ACK] Seq=0 Ack=1 Win=43690 Len=0 MSS=6…
56	58.65…	127.0.0.1	127.0.0.1	TCP	66	55490 → 3030 [ACK] Seq=1 Ack=1 Win=43776 Len=0 TSval=2194…
57	58.65…	127.0.0.1	127.0.0.1	TLSv1.2	5…	Client Hello
58	58.65…	127.0.0.1	127.0.0.1	TCP	66	3030 → 55490 [ACK] Seq=1 Ack=503 Win=44800 Len=0 TSval=21…
59	58.65…	127.0.0.1	127.0.0.1	TLSv1.2	1…	Server Hello, Certificate, Server Key Exchange, Server He…
60	58.65…	127.0.0.1	127.0.0.1	TCP	66	55490 → 3030 [ACK] Seq=503 Ack=1297 Win=174720 Len=0 TSva…
61	58.66…	127.0.0.1	127.0.0.1	TLSv1.2	1…	Client Key Exchange, Change Cipher Spec, Encrypted Handsh…
62	58.66…	127.0.0.1	127.0.0.1	TLSv1.2	3…	New Session Ticket, Change Cipher Spec, Encrypted Handsha…
63	58.66…	127.0.0.1	127.0.0.1	TLSv1.2	4…	Application Data
64	58.67…	127.0.0.1	127.0.0.1	TLSv1.2	3…	Application Data, Application Data
65	58.72…	127.0.0.1	127.0.0.1	TCP	66	55490 → 3030 [ACK] Seq=1048 Ack=1840 Win=179840 Len=0 TSv…

```
▸ Transmission Control Protocol, Src Port: 55490, Dst Port: 3030, Seq: 629, Ack: 1571, Len: 419
▾ Secure Sockets Layer
  ▾ TLSv1.2 Record Layer: Application Data Protocol: Application Data
    Content Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 414
    Encrypted Application Data: 7592f8a55438716e1e12768ab26faa7794ee41e0e481cc83...
```

```
0040  42 cd 17 03 03 01 9e 75  92 f8 a5 54 38 71 6e 1e   B·····u ···T8qn·
0050  12 76 8a b2 6f aa 77 94  ee 41 e0 e4 81 cc 83 9c   ·v··o·w· ·A·····
0060  6c 60 1e be 79 af 82 2d  19 ce 7f 9c a7 79 ad 1e   l`··y··- ·····y··
0070  2b 0c 17 ac 1c cf 71 06  a5 a8 0d a8 ca 37 46 ca   +·····q· ·····7F·
0080  ac 69 be ec 5d 84 20 b3  36 e2 aa 09 f7 97 1e c8   ·i··]· · 6·******
0090  c7 80 bd 4e 46 e3 e4 8f  fd 58 02 f6 d1 c5 cf ca   ···NF··· ·X******
```

HTTPS POST

Payload is encrypted application data (ssl.app_data), 414 bytes

Packets: 67 · Displayed: 67 (100.0%)

Profile: Default

HTTPS

Ещё один камень в огород REST API

HTTPS

Ещё один камень в огород REST API

/user?name=**Vadim**&lname=**Gorbachev**&dms=**123456**

CRYPTOGRAPHY

```
crypto.createHash('md5').update(password).digest('hex');
```

CRYPTOGRAPHY

```
crypto.createHash('md5').update(password).digest('hex');
```

123456	e10adc3949ba59abbe56e057f20f883e

Ок, кажется, теперь получше, да?

CRYPTOGRAPHY

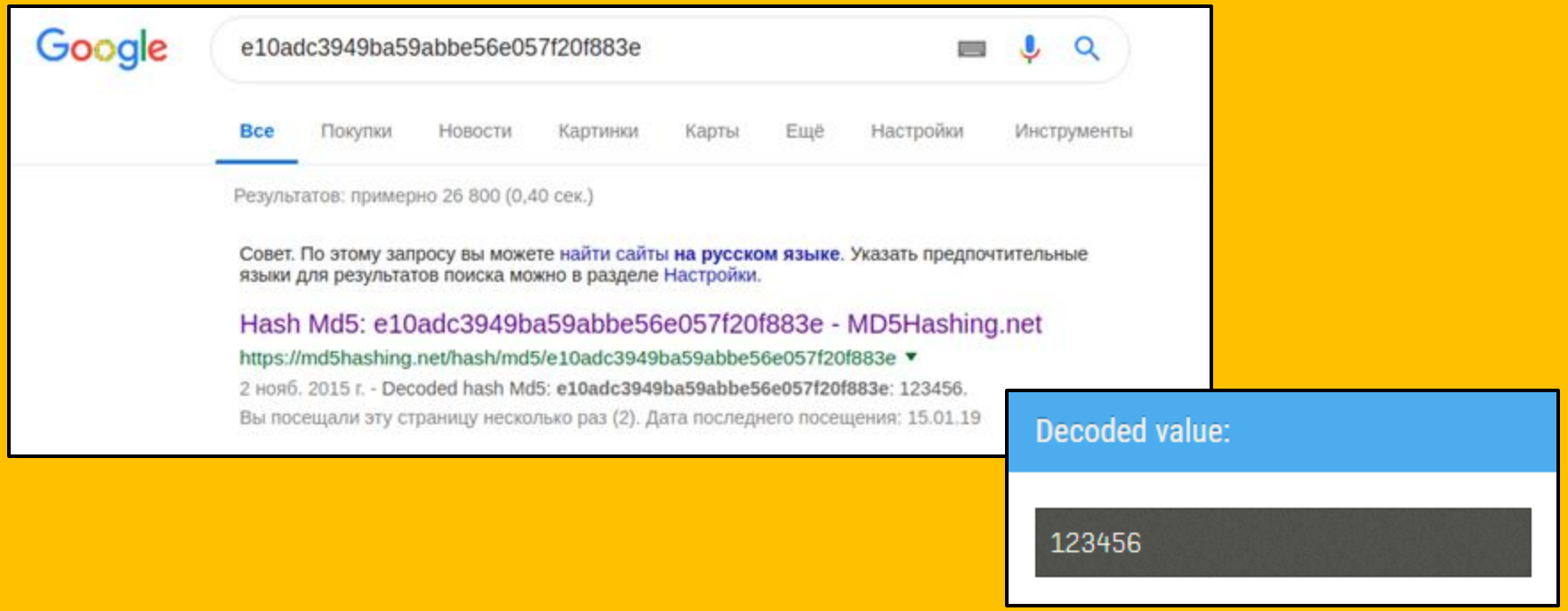
```
crypto.createHash('md5').update(password).digest('hex');
```

123456	e10adc3949ba59abbe56e057f20f883e

Ок, кажется, теперь получше, да?

НЕ СОВСЕМ

CRYPTOGRAPHY



CRYPTOGRAPHY

```
$$\   $$\            $$\                        $$\ $$\
$$ | $$  |           $$ |                       $$ |\__|
$$ |$$  /  $$$$$$\  $$$$$$\    $$$$$$\   $$$$$$\  $$ |$$\ $$$$$$$\
$$$$$  /   \____$$\ \_$$  _|  $$  __$$\ $$  __$$\ $$ |$$ |$$  __$$\
$$  $$<    $$$$$$$ |  Kali linux tools installer |$$ |$$ |$$ |  $$ |
$$ |\$$\  $$  __$$ |  $$ |$$\ $$ |  $$ |$$ |  $$ |$$ |$$ |$$ |  $$ |
$$ | \$$\ \$$$$$$$ |  \$$$$  |\$$$$$$  |\$$$$$$  |$$ |$$ |$$ |  $$ |
\__|  \__| \_______|   \____/  \______/  \_____/ \__|\__|\__|  \__| V1.1

+ -- -- +=[ Author: LionSec | Homepage: www.lionsec.net
+ -- -- +=[ 331 Tools
```

```
***************************** All Categories *****************************

1) Information Gathering                        8) Exploitation Tools
2) Vulnerability Analysis                       9) Forensics Tools
3) Wireless Attacks                             10) Stress Testing
4) Web Applications                             11) Password Attacks
5) Sniffing & Spoofing                          12) Reverse Engineering
6) Maintaining Access                           13) Hardware Hacking
7) Reporting Tools                              14) Extra

0) All
```

CRYPTOGRAPHY

```
$$\   $$\            $$\                          $$\ $$\
$$ | $$  |           $$ |                         $$ |\__|
$$ |$$  /  $$$$$$\  $$$$$$\    $$$$$$\   $$$$$$\  $$ |$$\ $$$$$$$\
$$$$$  /   \____$$\ \_$$  _|  $$  __$$\ $$  __$$\ $$ |$$ |$$  __$$\
$$  $$<    $$$$$$$ |  Kali linux tools installer |$$ |$$ |$$ |  $$ |
$$ |\$$\  $$  __$$ |  $$ |$$\ $$ |  $$ |$$ |  $$ |$$ |$$ |$$ |  $$ |
$$ | \$$\ \$$$$$$$ |  \$$$$  |\$$$$$$  |\$$$$$$  |$$ |$$ |$$ |  $$ |
\__|  \__| \_______|   \____/  \______/  \_____/ \__|\__|\__|  \__| V1.1


+ -- -- +=[ Author: LionSec | Homepage: www.lionsec.net
+ -- -- +=[ 331 Tools
```

```
=+[ Password Attacks

 1) acccheck                          19) Maskprocessor
 2) Burp Suite                        20) multiforcer
 3) CeWL                              21) Ncrack
 4) chntpw                            22) oclgausscrack
 5) cisco-auditing-tool               23) PACK
 6) CmosPwd                           24) patator
 7) creddump                          25) phrasendrescher
 8) crunch                            26) polenum
 9) DBPwAudit                         27) RainbowCrack
10) findmyhash                        28) rcracki-mt
11) gpp-decrypt                       29) RSMangler
12) hash-identifier                   30) SQLdict
13) HexorBase                         31) Statsprocessor
14) THC-Hydra                         32) THC-pptp-bruter
15) John the Ripper                   33) TrueCrack
16) Johnny                            34) WebScarab
17) keimpx                            35) wordlists
18) Maltego Teeth                     36) zaproxy

0) Install all Password Attacks tools
```

CRYPTOGRAPHY

```
$$\   $$\            $$\                          $$\ $$\
$$ | $$  |           $$ |                         $$ |\__|
$$ |$$  /  $$$$$$\  $$$$$$\    $$$$$$\   $$$$$$\  $$ |$$\ $$$$$$$\
$$$$$  /   \____$$\ \_$$  _|  $$  __$$\ $$  __$$\ $$ |$$ |$$  __$$\
$$  $$<    $$$$$$$ |  Kali linux tools installer |$$ |$$ |$$ |  $$ |
$$ |\$$\  $$  __$$ |  $$ |$$\ $$ |  $$ |$$ |  $$ |$$ |$$ |$$ |  $$ |
$$ | \$$\ \$$$$$$$ |  \$$$$  |\$$$$$$  |\$$$$$$  |$$ |$$ |$$ |  $$ |
\__|  \__| \_______|   \____/  \_____/  \_____/ \__|\__|\__|  \__| V1.1


+ -- -- +=[ Author: LionSec | Homepage: www.lionsec.net
+ -- -- +=[ 331 Tools
```

Не рекомендуется вводить в подобные инструменты боевые хэши.

$ findmyhash MD5 -h e10adc3949ba59abbe56e057f20f883e

***** HASH CRACKED!! *****

The original string is: 123456

The following hashes were cracked:

---

e10adc3949ba59abbe56e057f20f883e -> 123456

CRYPTOGRAPHY

```
const crypto = require('crypto');
const getFuncSHA512Salt = (salt) => {
    return (password) => {
        var hash = crypto.createHmac('sha512', salt);
        hash.update(password);
        var value = hash.digest( algorithm: 'hex');
        return value;
    }
};
const cryptoSHA512Salt = getFuncSHA512Salt(
    salt: "HVHSNrRWpP1ZSR4bnjXpiHCS1ENYcUuHO"
)
```

CRYPTOGRAPHY

```
const crypto = require('crypto');


const secret = 'abcdefg';
const hash = crypto.createHmac('sha256', secret)
                   .update('I love cupcakes')
                   .digest('hex');
console.log(hash);
// Prints:
//   c0fa1bc00531bd78ef38c628449c5102aeabd49b5dc3a2a516ea6ea959d6658e
```

COOL STORY 123456

Сковорода Никита Андреевич
@ChALker

2015-12-04

Express, EventEmitter2, mime-types, semver, npm, fstream, cookie (и cookies), **Bower**, Component, Connect, **koa**, co, tar, css, gm, csrf, keygrip, jcarousel, serialport, basic-auth, lru-cache, inflight, mochify, denodeify...

2015-12-04

Express, EventEmitter2, mime-types, semver, npm, fstream, cookie (и cookies), Bower, Component, Connect, koa, co, tar, css, gm, csrf, keygrip, jcarousel, serialport, basic-auth, lru-cache, inflight, mochify, denodeify...

2017-06-21

debug, qs, supports-color, yargs, commander, request, strip-ansi, chalk, form-data, mime, tunnel-agent, extend, delayed-stream, combined-stream, forever-agent, concat-stream, vinyl, co, express, escape-html, path-to-regexp, component-emitter, moment, ws, handlebars, connect, escodegen, got, gulp-util, ultron, http-proxy, dom-serializer, url-parse, vinyl-fs, configstore, coa, csso, formidable, color, winston, node-sass, react, react-dom, rx, postcss-calc, superagent, basic-auth, cheerio, jsdom, gulp, sinon, useragent, deprecated, browserify, redux, array-equal, bower, jshint, jasmine, global, mongoose, vhost, imagemin, highlight.js, tape, mysql, mz, nock, rollup, gulp-less, rework, xcode, ionic, cordova, normalize.css, electron, n, react-native, ember-cli, yeoman-generator, nunjucks, koa, modernizr, yo, mongoskin…

COOL STORY 123456

- 17 тыс. аккаунтов - 13%
- 73983 пакетов - 14%
- Через зависимости - 54%
- 4 пользователя из топ-20
- 42 с 10млн. загрузок в месяц
- 13 более 50 миллионов.

Пароль "password" одного из аккаунтов с доступом к koa

123456 - 662

123 - 174

password - 124

11% пользователей повторно использовали свои просочившиеся пароли: 10,6% - напрямую, и 0,7% — с очень незначительными изменениями.

COOL STORY 123456

Т.е. он мог бы контролировать

1 972 421 945

загрузок в месяц (напрямую),

это 20% от общего числа

COOL STORY 123456

Проверить, находится ли ваши данные в числе утекших можно здесь:

https://haveibeenpwned.com/

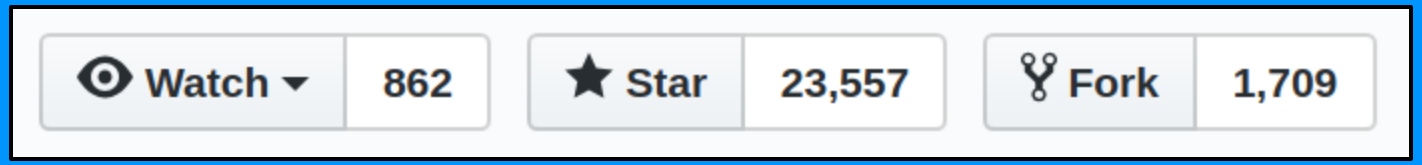
COOL STORY 123456

Возможно хороший способ себя обезопасить — использовать менеджеры паролей:
https://habr.com/ru/post/357192/
многие рекомендуют **1password**

продолжим..

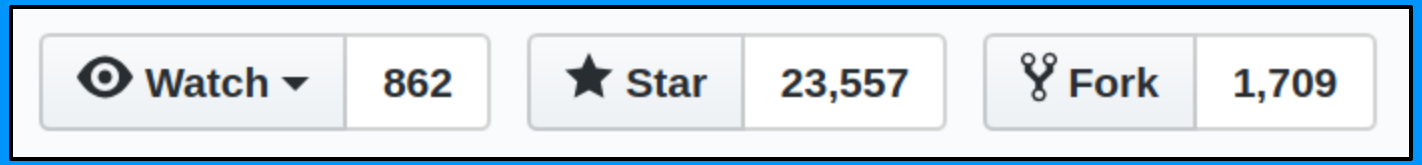
CRYPTOGRAPHY

i0natan/nodebestpractices



CRYPTOGRAPHY

i0natan/nodebestpractices



6.8. Avoid using the Node.js crypto library for handling passwords, use Bcrypt

CRYPTOGRAPHY

```
// asynchronously generate a secure password using 10 hashing rounds
bcrypt.hash('myPassword', 10, function(err, hash) {
  // Store secure hash in user record
});

// compare a provided password input with saved hash
bcrypt.compare('somePassword', hash, function(err, match) {
  if(match) {
   // Passwords match
  } else {
   // Passwords don't match
  }
});
```

CRYPTOGRAPHY

```
const bcrypt = require('bcrypt');
bcrypt.hash(
    data: "whatdoesthefoxsay",
    salt: 10,
    cb: function (err, hash) {
        // Store secure hash in user record
        db.createUser(conn, login: 'v7', hash)
    }
);
```

CRYPTOGRAPHY

```
// compare a provided password input with saved hash
bcrypt.compare(
    req.body.password,
    rows[0].password,
    cb: function (err, match) {
        res.send(match ? 'logged in' : 'bad news');
    }
);
```

CRYPTOGRAPHY

Но есть еще одно “но”!

CRYPTOGRAPHY

```
const sendRequest = function (login, password) {
    const result = {
        login,
        password
    };
    const promise = new Promise( executor: function (res, rej) {
        result.start = Date.now(),
            request.post(
                'http://127.0.0.1:3030/api/v1/login',
                {json: {login, password}},
                function (error, response, body) {
                    if (!error && response.statusCode === 200) {
                        result.end = Date.now();
                        res(result);
                    }
                }
            );
    });
    return promise;
}
```

CRYPTOGRAPHY

Отправим по 10 запросов на login in [‘v7’, ‘v7_wrong’]:

CRYPTOGRAPHY

Отправим по 10 запросов на login in [‘v7’, ‘v7_wrong’]:

```
$ node ./attaker.js
v7 - 917mc
v7_wrong - 40mc
```

CRYPTOGRAPHY

Отправим по 10 запросов на login in [‘v7’, ‘v7_wrong’]:

```
$ node ./attaker.js
v7 - 837mc
v7_wrong - 42mc
```

CRYPTOGRAPHY

А давайте проверить как это работает с **sha512**:

```
$ node ./attaker.js
v6 54
v6_wrong 32
```

CRYPTOGRAPHY

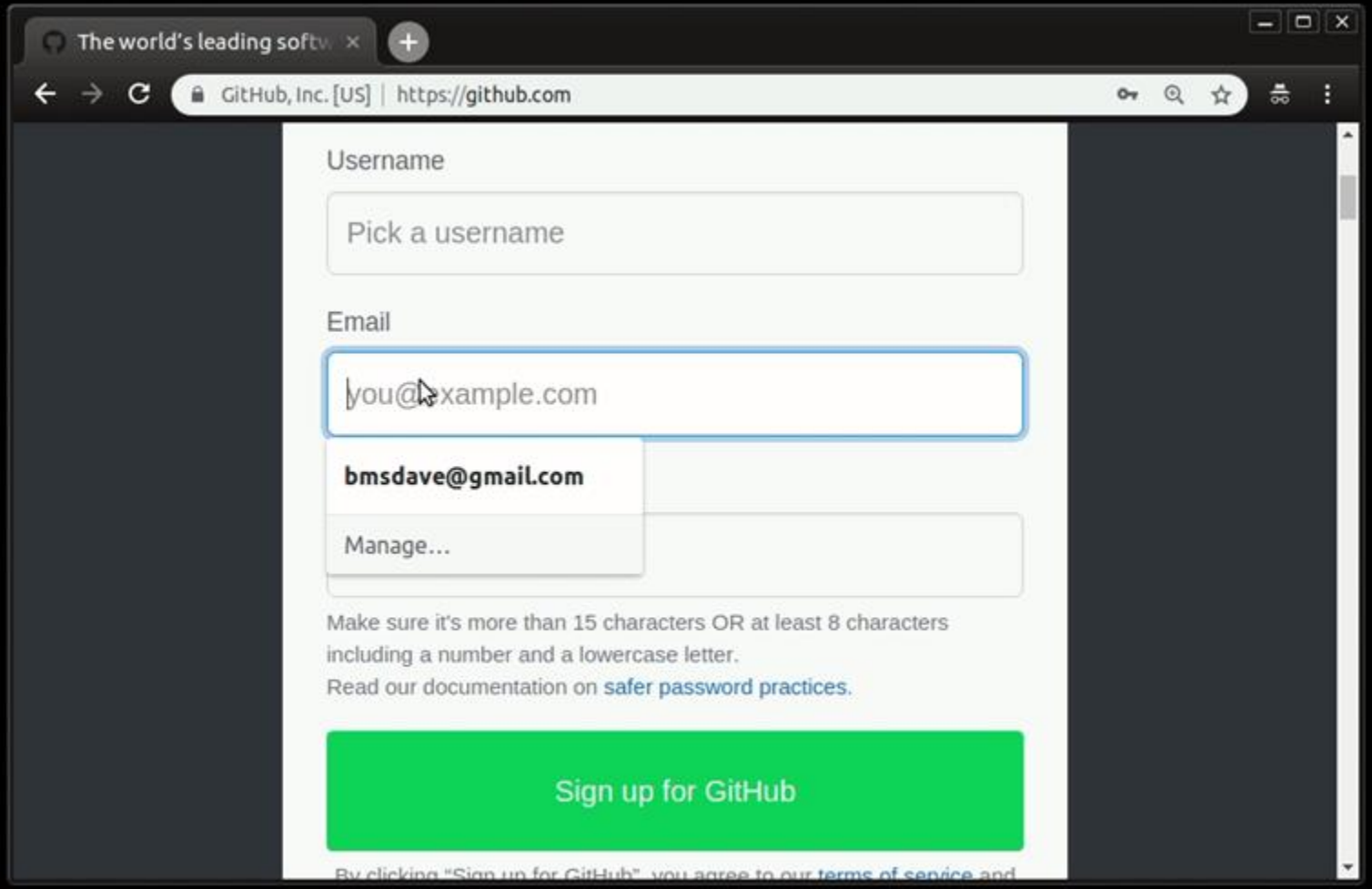
```
if (rows && rows.length > 0) {
    // compare a provided password input with saved hash
    bcrypt.compare(
        req.body.password,
        rows[0].password,
        cb: function (err, match) {
            res.send(match ? 'logged in' : 'bad news');
        }
    );
} else {
    bcrypt.compare(
        req.body.password,
        randomPassword,
        cb: function (err, match) {
            res.send('bad news');
        }
    );
}
```

CRYPTOGRAPHY

```
$ node ./attaker.js
v7 - 786mc
v7_wrong - 778mc
```

USABILITY

Про форму регистрации. Давать ли возможность проверять занят ли такой **e-mail**


The world's leading softw
GitHub, Inc. [US] | https://github.com
Username
Pick a username
Email
you@example.com
bmsdave@gmail.com
Manage...
Make sure it's more than 15 characters OR at least 8 characters including a number and a lowercase letter.
Read our documentation on safer password practices.
Sign up for GitHub

USABILITY

```
const puppeteer = require('puppeteer');
const symbolsArr = "qwertyuiopasdfghjklzxcvbnm1234567890".split('');

(async () => {
    const browser = await puppeteer.launch({headless: true});
    const page = await browser.newPage();
    await page.goto('https://blabla.site/register/');

    await runForAll(page, limit: 9);
    await browser.close();
})();
```

```
const checkLogin = async (login, page) => {
    const result = JSON.parse(await page.evaluate(async (login) => {
        return await new Promise( executor: (resolve, reject) => {
            try {
                const email = `${login}@gmail.com`
                $.post(
                    "/check_email/",
                    {value: email, name: "email"},
                    function (json) {
                        resolve(JSON.stringify( value: {
                            exist: json.messages !== 'ok',
                            email: email
                        }))
                    })
            } catch (err) {
                reject(err.toString());
            }
        });
    }, login));
    if (result.exist) {
        console.log(`${result.email}`);
    }
    return result;
}
```

Список литературы

Курс MIT «Безопасность компьютерных систем»

Ответы юриста: как избежать ответственности за поиск уязвимостей

Про Мэта Хонан

psycopg2: The problem with the query parameters

Тайминговая атака на Node.js — когда время работает против вас

Исследование @ChALkeR

Node.js best practices list

Node.js Security Working Group

Юзабилити форм авторизации

Выводы

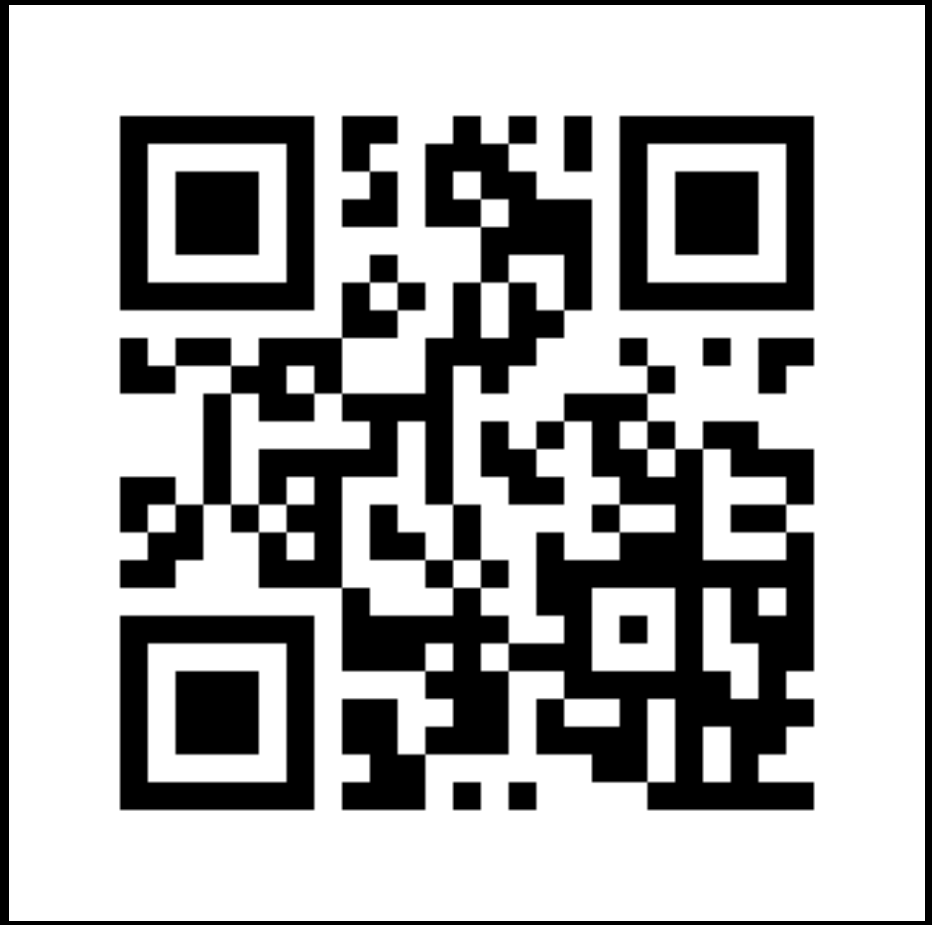
- Экранируйте запросы в БД
- Используйте HTTPS POST для чувствительных данных
- Не используйте MD5
- Используйте соль
- Ничто не безопасно на 100%
- Следите за своими паролями и паролями пользователей
- Между usability и безопасность стоит искать баланс

Node.js best practices list
Node.js Security Working Group

Спасибо!

Вопросы?

https://bit.ly/2uwHLbj



Вадим Горбачев
@bmsdave